

מבחן קצר — בדוק את עצמך

חומר לימוד

1 יחידות

תוכן העניינים

1.  מבחן קצר — "בדוק את עצמך"

מבחן קצר — “בדוק את עצמך”

שם: _____ תאריך: _____ ציון: _____ 55 /

סמן את התשובה הנכונה (א / ב / ג) לכל שאלה. בהצלחה! 

מודול 1 — מבוא, המעבדה ומתודולוגיה

1. בהדגמה, מהי החולשה (Vulnerability)?

- (א) שהתוכנית כתובה בפייתון
- (ב) שהסיסמה נשמרה גלויה בתוך קוד המקור
- (ג) ש- strings היא פקודה מסוכנת

התשובה שלי: _____

2. לפי המתודולוגיה, מה עושים מיד לפני “השגת גישה” (Gaining Access)?

- (א) טשטוש עקבות
- (ב) סריקה ומיפוי (Scanning & Enumeration)
- (ג) כתיבת הדוח

התשובה שלי: _____

3. באיזה מצב רשת ה-VM מבודד לגמרי מהרשת הביתית שלך (בלי אינטרנט)?

- (א) Bridged
- (ב) NAT
- (ג) Host-Only

התשובה שלי: _____

4. איפה נמצאות רשימות המילים (Wordlists) לתקיפת סיסמאות ב-Kali?

- (א) /home/kali/
- (ב) /usr/share/wordlists/
- (ג) /etc/passwords/

התשובה שלי: _____

מודול 2 — יסודות Linux (Linux Fundamentals)

1. איזו פקודה תראה קבצים מוסתרים (שמתחילים ב-`.`)?

• (א) `ls`

• (ב) `ls -la`

• (ג) `cd ..`

התשובה שלי: _____

2. מה עושה `grep "password" app.log`?

• (א) מוחק את השורות עם `password`

• (ב) מדפיס רק את השורות שמכילות `password`

• (ג) מצפין את הקובץ

התשובה שלי: _____

3. מה מיוחד בקובץ עם ביט SUID?

• (א) הוא מוסתר מ-`ls`

• (ב) הוא רץ בהרשאות הבעלים שלו, לא של מי שמריץ

• (ג) אי אפשר למחוק אותו

התשובה שלי: _____

4. מה עושה הצינור `| base64 -d` בפקודה `grep flag file`?

• (א) מריץ שתי פקודות נפרדות בלי קשר

• (ב) מעביר את הפלט של `grep` כקלט ל-`base64 -d`

• (ג) שומר את הפלט לקובץ

התשובה שלי: _____

מודול 3 — יסודות רשתות (Networking Fundamentals)

1. מה מייצגת כל שורה בפלט של `tracert`?

- (א) פורט פתוח על היעד
- (ב) ראוטר (תחנה) בדרך ליעד
- (ג) חבילה שאבדה

התשובה שלי: _____

2. השורה `GET / HTTP/1.1` > שראית ב- `curl -v` שייכת לאיזו שכבה?

- (א) שכבה 3 (Network)
- (ב) שכבה 4 (Transport)
- (ג) שכבה 7 (Application)

התשובה שלי: _____

3. איזו פקודה מציגה את שכבה 4 (פורטים וחיבורים)?

- (א) `ip a`
- (ב) `ss -tunp`
- (ג) `curl`

התשובה שלי: _____

4. מהו הדגל הראשון (`Flags [S]`) שראית ב- `tcpdump` ?

- (א) `ACK`
- (ב) `SYN`
- (ג) `FIN`

התשובה שלי: _____

5. הכתובת `192.168.56.10` היא —

- (א) ציבורית
- (ב) פרטית
- (ג) Loopback

התשובה שלי: _____

6. מה `ARP` ממפה?

• (א) שם דומיין → IP

• (ב) IP → MAC

• (ג) פורט → שירות

התשובה שלי: _____

7. אחרי שעצרת את השרת (Ctrl+C), למה ss כבר לא מצא את פורט 5000?

• (א) הפורט תמיד סגור

• (ב) השירות שפתח אותו הפסיק לרוץ

• (ג) nmap מחק אותו

התשובה שלי: _____

8. כמה מארחים שמישים יש בתת-רשת 24 / ?

• (א) 256

• (ב) 254

• (ג) 512

התשובה שלי: _____

9. הפקודה ping משתמשת באיזה פרוטוקול?

• (א) TCP

• (ב) UDP

• (ג) ICMP

התשובה שלי: _____

10. מה עושה TCP Stream Follow ב-Wireshark?

• (א) סוגר את החיבור

• (ב) מציג את כל השיחה בין שני הצדדים בתצוגה אחת

• (ג) סורק פורטים

התשובה שלי: _____

מודול 4 — סקריפטינג: Bash ו-Python (Scripting for Hackers)

1. קיבלת `Permission denied` על סקריפט חדש. מה חסר?

- (א) שכחת את ה-Shebang
- (ב) לא נתת הרשאת הרצה (`chmod +x`)
- (ג) הקובץ ריק

התשובה שלי: _____

2. מה תפקיד ה- `&` בסוף שורת ה- `ping` בלולאה?

- (א) מריץ כל `ping` ברקע, כך שכולם רצים במקביל (מהיר)
- (ב) מפנה את הפלט לקובץ
- (ג) עוצר את הלולאה

התשובה שלי: _____

3. בסורק, מתי הפורט נחשב פתוח?

- (א) כש- `connect_ex` מחזיר מספר כלשהו
- (ב) כש- `connect_ex` מחזיר 0
- (ג) כשמופיעה שגיאה

התשובה שלי: _____

4. מה עשה את השרת פגיע ל-Brute Force?

- (א) שהוא כתוב בפייתון
- (ב) PIN קצר (4 ספרות) בלי הגבלת מספר נסיונות
- (ג) שהוא רץ על פורט 9999

התשובה שלי: _____

מודול 5 — איסוף מידע (Reconnaissance)

1. איזו פעולה היא פסיבית?

- (א) הרצת `nmap` על שרת היעד

• (ב) `whois` על הדומיין (שאלתה למאגר רישום ציבורי)

• (ג) `ping` ליעד

התשובה שלי: _____

2. למה `Server: Apache/2.4.49` בכותרת מסוכן לארגון?

• (א) זה חושף את הגרסה המדויקת, ותוקף יכול לחפש חולשה ידועה לאותה גרסה

• (ב) זה מאט את האתר

• (ג) זה חוסם את גוגל

התשובה שלי: _____

3. מה הטעות ב"הסתרת" נתיב רק דרך `robots.txt`?

• (א) `robots.txt` מאט את השרת

• (ב) הקובץ ציבורי וקריא לכולם — הוא בעצם מפרסם את הנתיבים שרצית להסתיר

• (ג) גוגל חוסם את האתר

התשובה שלי: _____

מודול 6 — סריקה, מיפוי והערכת חולשות (Scanning & Enumeration)

1. מה עושה `nmap -sn`?

• (א) סורק את כל 65,535 הפורטים

• (ב) גילוי מארחים חיים בלבד, בלי סריקת פורטים

• (ג) מזהה מערכת הפעלה

התשובה שלי: _____

2. מהו "Banner Grabbing"?

• (א) חסימת פורט

• (ב) התחברות לשירות וקריאת המידע (כולל גרסה) שהוא מציג

• (ג) הצפנת התעבורה

התשובה שלי: _____

3. מה עושה `gobuster dir` ?

- (א) מנחש שמות של נתיבים/קבצים באתר לפי רשימת מילים, ומדווח אילו קיימים
- (ב) מפיל את השרת
- (ג) מפענח סיסמאות

התשובה שלי: _____

4. מה מספק `searchsploit apache 1.3.20` ?

- (א) מפעיל אוטומטית Exploit על היעד
- (ב) מחפש במאגר Exploit-DB המקומי חולשות ידועות לגרסה הזו
- (ג) מעדכן את Apache

התשובה שלי: _____

מודול 7 — ניצול והשגת גישה (Exploitation)

1. ב-Reverse Shell, מי יוזם את החיבור?

- (א) התוקף מתחבר לקורבן
- (ב) הקורבן מתחבר לתוקף (שמאזין)
- (ג) אף אחד — זה אוטומטי

התשובה שלי: _____

2. מה גרם לחולשת ה-Command Injection?

- (א) שהשרת כתוב בפייתון
- (ב) שקלט המשתמש שורשר ישירות לפקודת shell (`shell=True`) בלי סינון
- (ג) שהפורט הוא 8080

התשובה שלי: _____

מודול 8 — מתקפות סיסמאות (Password Attacks)

1. Hash שמתחיל ב-\$6\$ הוא —

- (א) MD5

- (ב) sha512crypt (סיסמת Linux מ- /etc/shadow)
- NTLM (ג)

התשובה שלי: _____

2. מה תפקיד המחרוזת `Invalid credentials` בפקודת Hydra?

- (א) הסיסמה לפריצה
- (ב) "סימן הכישלון" — כל עוד היא בתשובה, ההתחברות נכשלה; היעדרה = הצלחה
- (ג) שם המשתמש

התשובה שלי: _____

3. למה מתקפה לא-מקוונת (John על Hash) מהירה ושקטה יותר ממקוונת (Hydra)?

- (א) כי היא לא שולחת בקשות ליעד — הסדיקה מתבצעת מקומית על המחשב שלך
- (ב) כי John חזק מ-Hydra
- (ג) כי Hash-ים תמיד קצרים

התשובה שלי: _____

מודול 9 — אבטחת אפליקציות (OWASP Top 10) Web

1. מה מנטרל SQL Injection בצורה הטובה ביותר?

- (א) להסתיר את הודעות השגיאה
- (ב) Prepared Statements / Parameterized Queries — הפרדת קוד מנתונים
- (ג) HTTPS

התשובה שלי: _____

2. מה מונע Reflected XSS?

- (א) קידוד הפלט (Output Encoding) — הצגת `<script>` כטקסט ולא כקוד
- (ב) שימוש ב-POST במקום GET
- (ג) הסתרת שם השרת

התשובה שלי: _____

3. למה Command Injection נחשבת מהחולשות החמורות ביותר?

- (א) היא מאטה את האתר
- (ב) היא מאפשרת הרצת קוד כלשהו על השרת (RCE) — שליטה מלאה
- (ג) היא חושפת רק את שם השרת

התשובה שלי: _____

4. מהו IDOR?

- (א) הצפנה חלשה
- (ב) גישה למשאב של משתמש אחר ע"י שינוי מזהה חשופי, בהיעדר בדיקת הרשאה בשרת
- (ג) הזרקת JavaScript

התשובה שלי: _____

מודול 10 — גלישת חוצץ (Buffer Overflow)

1. מדוע 16 בתים לא הספיקו, אבל 17 כן?

- (א) כי החוצץ בגודל 16, והבית ה-17 כבר "גלש" ודרס את המשתנה הסמוך
- (ב) כי 17 הוא מספר ראשוני
- (ג) כי strcpy עובד רק מעל 16 בתים

התשובה שלי: _____

2. מהי המטרה של שלב מציאת ה-Offset?

- (א) ליצור את ה-Shellcode
- (ב) לדעת בדיוק בכמה בתים נדרס ה-EIP, כדי למקם שם את הכתובת שנבחר
- (ג) לפתוח מאזין

התשובה שלי: _____

מודול 11 — פוסט-אקספלוויטציה והסלמת הרשאות (Post-Exploitation & Privilege Escalation)

1. למה קובץ SUID בבעלות root מסוכן?

- (א) הוא תופס הרבה מקום
- (ב) הוא רץ בהרשאות root גם כשמשתמש מוגבל מפעיל אותו — ואם ניתן “לברוח” ממנו, מקבלים root
- (ג) אי אפשר למחוק אותו

התשובה שלי: _____

2. ב-Windows, איזו פקודה מציגה את ההרשאות המיוחדות של המשתמש (כמו SeImpersonatePrivilege)?

- (א) `whoami /priv`
- (ב) `ipconfig /all`
- (ג) `net user`

התשובה שלי: _____

מודול 12 — Pivoting ותנועה רוחבית (Pivoting & Tunneling)

1. מה עושה `ssh -L 8080:10.10.10.30:80 user@pivot`?

- (א) מריץ nmap על ה-pivot
- (ב) פותח פורט מקומי 8080 שמנתב, דרך ה-pivot, אל 10.10.10.30:80 שברשת הפנימית
- (ג) מוחק את הלוגים ב-pivot

התשובה שלי: _____

2. למה חובה `-sT` (ולא `-sS`) כשמריצים nmap דרך `proxychains`?

- (א) `-sT` מהיר יותר
- (ב) פרוקסי SOCKS מעביר רק חיבורי TCP מלאים; סריקת SYN (`-sS`) חצי-פתוחה לא עוברת דרכו
- (ג) `-sS` דורש סיסמה

התשובה שלי: _____

מודול 13 — Active Directory (AD)

1. מה משיג התוקף מ-LLMNR/NBT-NS Poisoning עם Responder?

- (א) גישת Domain Admin מיידית

- (ב) את ה-NTLMv2 hash של משתמש שניסה לגשת לשם שגוי — לפיצוח offline
- (ג) את סיסמת ה-krbtgt

התשובה שלי: _____

2. מדוע כל משתמש דומיין (גם מוגבל) יכול לבצע Kerberoasting?

- (א) כי כולם Domain Admins
- (ב) כי כל משתמש מאומת רשאי לבקש TGS של חשבונות שירות (SPN), וה-TGS מוצפן בסיסמת השירות — שנפצחת offline
- (ג) כי ה-DC פגיע לבאג

התשובה שלי: _____

3. מדוע NTLM hashes נחשבים חלשים יחסית לפיצוח?

- (א) הם ארוכים מדי
- (ב) הם MD4 של הסיסמה — ללא Salt וללא האטה — כך שאפשר לנסות מיליארדי ניחושים בשנייה
- (ג) אי אפשר לפצח אותם כלל

התשובה שלי: _____

מודול 14 — תקיפות אלחוטיות (Wireless Attacks)

1. מצאת רשת שעדיין משתמשת ב-WEP. מה המשמעות?

- (א) הרשת בטוחה מאוד
- (ב) ממצא קריטי — WEP שבור לחלוטין וניתן לפיצוח תוך דקות
- (ג) אי אפשר לתקוף אותה

התשובה שלי: _____

2. למה שולחים חבילות Deauthentication ללקוח מחובר?

- (א) כדי לפצח את הסיסמה ישירות
- (ב) כדי לנתק אותו — שיתחבר מחדש, וכך נלכוד את ה-4-Way Handshake
- (ג) כדי להאיץ את הרשת

התשובה שלי: _____

3. מה הופך רשת WPA2 לעמידה בפני הפיצוח הזה?

- (א) הסתרת ה-SSID
- (ב) סיסמה ארוכה ואקראית שאינה נמצאת באף wordlist
- (ג) כיבוי ה-Handshake

התשובה שלי: _____

4. איך מתקפת Evil Twin משיגה את הסיסמה גם כשה-WPA2 חזק מדי לפיצוח?

- (א) היא מפצחת את ה-Handshake מהר יותר
- (ב) היא מקימה AP מזויף עם אותו שם ומרמה את המשתמש להקליד את הסיסמה בעצמו (Captive Portal)
- (ג) היא משביתה את ה-WPA3

התשובה שלי: _____

מודול 15 — הנדסה חברתית ופשינג (Social Engineering & Phishing)

1. קיבלת מייל מ- `it-suport@company.com` (שים לב לאיות) עם "אמת את חשבונך תוך שעה או שייחסם". אילו שני סימני פשינג בולטים כאן?

- (א) דומיין/כתובת עם שגיאת כתיב + יצירת דחיפות ואיום
- (ב) המייל ארוך מדי
- (ג) אין בו לוגו

התשובה שלי: _____

2. למה MFA מקטין את הנזק מדרך נחיתה כזו?

- (א) הוא מונע מהדף להיטען
- (ב) גם אם הסיסמה נגנבת, לתוקף חסר הגורם השני (קוד/אישור) כדי להיכנס
- (ג) הוא מצפין את הסיסמה

התשובה שלי: _____

מודול 16 — כתיבת דוח ותיעוד (Reporting)

1. איזה חלק בממצא הופך אותו לניתן לשחזור ע"י צוות ה-IT?

- (א) כותרת הממצא
- (ב) ה-Proof of Concept (צעדים מדויקים + פקודות + צילומים)
- (ג) ההפניות ל-CVE

התשובה שלי: _____

2. איזה ממצא יקבל את ה-CVSS הגבוה ביותר, ככלל?

- (א) Command Injection המאפשר RCE לא-מאומת מרחוק על שרת ציבורי
- (ב) חולשת Low בדף פנימי
- (ג) כותרת Server חושפנית

התשובה שלי: _____